Actividad 1

Campo	¿Identifica directamente?	¿Puede contribuir a identificar?	¿Requiere protección?	Justificación
id	SI	SI	SI	Identificador único del registro en la base de datos
nombre	SI	SI	SI	Identificador directo, revela la identidad de la persona física.
correo	SI	SI	SI	Identificador directo, suele contener nombre/apellido y es único del usuario
telefono	SI	SI	SI	Identificador directo de contacto vinculable a una persona.
rfc	SI	SI	SI	Identificador único oficial que contiene la fecha de nacimiento e iniciales.
edad	NO	SI	SI	Cuasi-identificador, acota el perfil del individuo.
ciudad	NO	SI	SI	Cuasi-identificador demográfico.
codigo_postal	NO	SI	SI	Cuasi-identificador de ubicación geográfica específica.
fecha_alta	NO	SI	SI	Dato operativo, combinado con otros datos ayuda a precisar el registro.

1. ¿Qué campos identifican directamente a una persona? nombre, correo, telefono y rfc.
2. ¿Qué campos no identifican por sí mismos pero podrían contribuir a hacerlo? edad, ciudad y codigo_postal (cuasi-identificadores).

3. ¿Qué combinación de campos podría incrementar el riesgo de reidentificación? La combinación de edad + ciudad + codigo_postal (o fecha_alta).
4. ¿Todos los datos que deben protegerse son necesariamente datos personales sensibles desde el punto de vista jurídico? No. Muchos son datos personales identificables (como el teléfono o correo), mientras que un dato sensible suele ser religión, salud, preferencia sexual u origen étnico. Aun así, los identificadores directos requieren protección.

Actividad 2

1. ¿Qué información continúa existiendo en la tabla original? La información completa y real (en texto plano) sin alteraciones.
2. ¿Qué información puede visualizar el usuario soporte? El id, el nombre completo y las versiones enmascaradas con asteriscos de correo, telefono y rfc.
3. ¿Por qué no es suficiente ocultar los datos únicamente en la aplicación? Porque si un usuario o atacante logra conectarse directamente a la base de datos o exploiting un fallo en la API, podría consultar la tabla directamente y extraer los datos en texto claro si no existen restricciones a nivel de base de datos.
4. ¿Qué ocurriría si soporte tuviera acceso directo a clientes? Podría ver los correos, teléfonos y RFCs completos de todos los usuarios sin justificación operativa, violando el principio de mínimo privilegio y aumentando el riesgo de fuga de información.

Actividad 4

1. ¿Qué ocurriría si analista pudiera consultar también pii.mapa_cliente? Podría hacer un JOIN entre analitica.clientes y pii.mapa_cliente para obtener el cliente_id real, anulando completamente el objetivo de la seudonimización.
2. ¿Qué principio de seguridad se está aplicando al separar ambos accesos? El Principio de Mínimo Privilegio y el principio de Separación de Funciones (Separation of Duties).
3. ¿Por qué la seudonimización no equivale a anonimización? Porque los datos aún pueden reidentificarse mediante el uso de la tabla de correspondencia (es un proceso reversible).
4. ¿Qué información permite volver a relacionar el token con una persona? La tabla de mapa de correspondencia pii.mapa_cliente que une el token con el cliente_id.

Actividad 6

1. ¿Qué identificadores directos fueron eliminados? nombre, correo, telefono, rfc e id.
2. ¿Qué cuasi-identificadores permanecen? edad y codigo_postal.
3. ¿Qué combinaciones de atributos podrían reducir el anonimato? Si se cruzan combinaciones de rangos de edad con regiones muy específicas o si se añaden variables como género o fecha de registro.
4. ¿Qué sucede cuando un grupo contiene pocos registros? Se vuelve vulnerable a ataques de reidentificación por inferencia (por ejemplo, si en una región solo hay 1 persona de '46+', se sabrá quién es).
5. ¿Qué atributos deberían generalizarse? Edades exactas, fechas precisas y códigos postales de 5 dígitos.
6. ¿Qué información debería suprimirse? Cualquier combinación de grupo cuya frecuencia ($COUNT$) sea inferior a un umbral seguro (k-anonimato).
7. ¿Es correcto afirmar que el conjunto de datos es “100 % anónimo”? No ¿Por qué? La anonimización 100% absoluta casi no existe, ya que al combinar datos agregados con fuentes de datos externas o información auxiliar siempre puede existir riesgo residual de reidentificación.

Actividad 7

Registros afectados: Aquellos donde fecha_alta sea inferior a 5 años atrás respecto a la fecha actual.

Justificación del periodo: Cumplimiento con políticas de minimización de datos y regulaciones legales que exigen no conservar datos personales más allá de la finalidad comercial o legal exigida.

Aprobación requerida: Firma del Oficial de Privacidad / Compliance Officer y aprobación del DBA principal.

Respaldo: Generación de un backup comprimido y cifrado antes de ejecutar cualquier purga masiva.

Evidencia a conservar: Logs de ejecución del proceso de depuración (con cantidad de filas eliminadas, timestamp y usuario ejecutor) en la bitácora de auditoría.

Procedimiento de recuperación: Restauración desde la copia de seguridad cifrada guardada en almacenamiento frío en caso de eliminación por error.

Preguntas de Reflexión

1. ¿Cuál es la diferencia entre enmascaramiento y seudonimización? El enmascaramiento altera la representación visual del dato para ocultar parte de su contenido sin modificar necesariamente el valor original o crear un nuevo identificador. La seudonimización sustituye la identidad directa por un valor sustituto (token) guardando la equivalencia en una tabla protegida e independiente.
2. ¿Por qué la seudonimización no significa anonimización? Porque la seudonimización es reversible; mientras exista la tabla de correspondencia o información adicional, se puede volver a identificar al titular.
3. ¿Por qué eliminar nombre y RFC no garantiza que un conjunto de datos sea anónimo? Porque los datos restantes (como edad, código postal, género) actúan como cuasi-identificadores que al combinarse pueden aislar a un individuo dentro de un grupo.
4. ¿Qué función tienen los cuasi-identificadores? Son atributos que individualmente no identifican a una persona, pero cruzados entre sí o con datos externos permiten la reidentificación.
5. ¿Por qué es importante separar el mapa de seudonimización? Porque si un atacante o usuario analista obtiene el mapa, la seudonimización queda totalmente anulada.
6. ¿Qué principio de seguridad se aplica al impedir que el analista acceda al mapa? Separación de funciones (Separation of Duties) y Mínimo Privilegio.
7. ¿Por qué una vista puede ser preferible a entregar acceso directo a la tabla? Porque permite restringir el acceso a nivel de columnas o aplicar funciones de transformación al vuelo sin duplicar datos ni arriesgar la tabla base.
8. ¿Qué diferencia existe entre proteger un dato para visualización y protegerlo contra acceso no autorizado? Proteger la visualización (enmascaramiento) evita miradas no deseadas en interfaces; proteger contra acceso no autorizado (GRANT/REVOKE) impide que los roles ejecuten consultas directo sobre las estructuras subyacentes.
9. ¿Por qué la retención forma parte de la protección de datos? Porque promueve el principio de minimización de datos: a menor cantidad de datos obsoletos conservados, menor es el impacto de un incidente de seguridad.
10. ¿Qué riesgo existe si una organización conserva información indefinidamente? Aumenta innecesariamente el volumen de datos expuestos ante brechas de seguridad y puede resultar en sanciones legales por inclumplimiento regulatorio de privacidad.